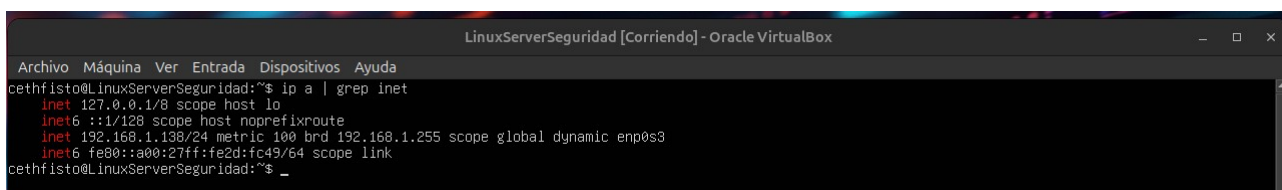


Reto: Bloque 4 Día 21

Fase: 1

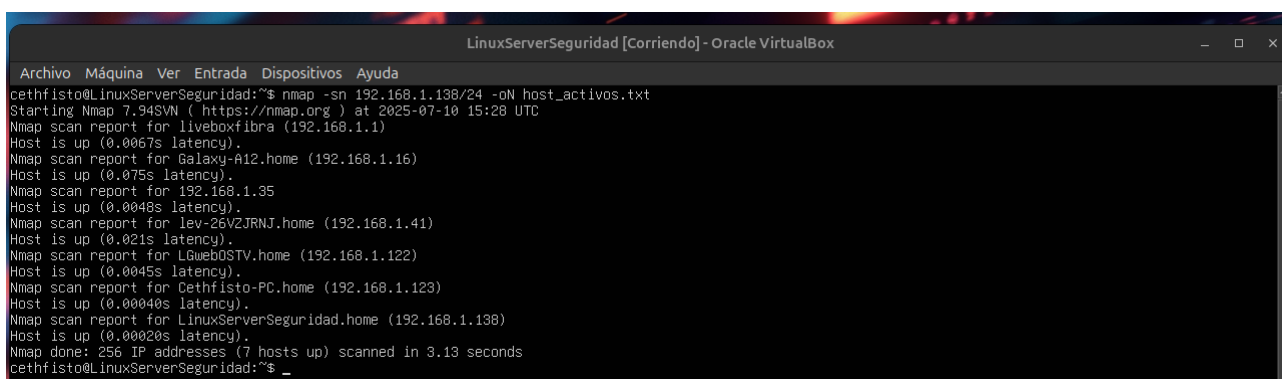
Instalaremos nmap para detectar equipos activos en la red local. Identificar puerto abiertos y servicios que están expuestos. Detectaremos SO y versiones. Y registraremos qué servidores responden a SSH, HTTP, FTP, etc.

Para empezar instalaremos Nmap. Usaremos el comando `sudo apt install nmap`. Y una vez instalado tendremos que conocer la IP y la subred.

A terminal window titled 'LinuxServerSeguridad [Corriendo] - Oracle VirtualBox'. The prompt is 'cethfisto@LinuxServerSeguridad:~\$'. The command 'ip a | grep inet' is entered, showing four lines of output: 'inet 127.0.0.1/8 scope host lo', 'inet6 ::1/128 scope host noprefixroute', 'inet 192.168.1.138/24 metric 100 brd 192.168.1.255 scope global dynamic enp0s3', and 'inet6 fe80::a00:27ff:fe2d:fc49/64 scope link'. The prompt returns to 'cethfisto@LinuxServerSeguridad:~\$'.

* Nuestra IP será 192.168.1.138.

Para descubrir los host activos en nuestra red. Usaremos el comando `nmap -sn 192.168.1.0/24`.

A terminal window titled 'LinuxServerSeguridad [Corriendo] - Oracle VirtualBox'. The prompt is 'cethfisto@LinuxServerSeguridad:~\$'. The command 'nmap -sn 192.168.1.138/24 -oN host_activos.txt' is entered. The output shows 'Starting Nmap 7.94SVN (https://nmap.org) at 2025-07-10 15:28 UTC', followed by 'Nmap scan report for liveboxfibra (192.168.1.1)' and 'Host is up (0.0067s latency)'. This is followed by seven more lines, each reporting a scan for a different host (Galaxy-A12.home, 192.168.1.35, lev-26VZJRNJ.home, L6webOSTV.home, Cethfisto-PC.home, LinuxServerSeguridad.home) and confirming they are up with latency. The final line is 'Nmap done: 256 IP addresses (7 hosts up) scanned in 3.13 seconds'. The prompt returns to 'cethfisto@LinuxServerSeguridad:~\$'.

* Aquí tenemos una lista de los equipos que hay en la red.

Para ver los SO. Usaremos el comando `sudo nmap -O 192.168.1.0/24`.

```
LinuxServerSeguridad [Corriendo] - Oracle VirtualBox
Archivo  Máquina  Ver  Entrada  Dispositivos  Ayuda
Starting Nmap 7.94SUN ( https://nmap.org ) at 2025-07-10 17:16 UTC
Nmap scan report for liveboxfibra (192.168.1.1)
Host is up (0.017s latency).
Not shown: 993 closed tcp ports (reset)
PORT      STATE SERVICE
53/tcp    open  domain
80/tcp    open  http
139/tcp   open  netbios-ssn
443/tcp   open  https
445/tcp   open  microsoft-ds
6969/tcp  open  acasoda
8080/tcp  filtered http-proxy
MAC Address: 64:CC:22:4B:9E:67 (Arcadyan)
Device type: general purpose
Running: Linux 2.6.X13.X
OS CPE: cpe:/o:linux:linux_kernel:2.6 cpe:/o:linux:linux_kernel:3
OS details: Linux 2.6.32 - 3.13
Network Distance: 1 hop

Nmap scan report for leu-260ZJRMJ.home (192.168.1.41)
Host is up (0.059s latency).
Not shown: 999 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    filtered ssh
MAC Address: 90:23:C1:37:F8:5E (Securitas Direct AB)
Too many fingerprints match this host to give specific OS details
Network Distance: 1 hop

Nmap scan report for Cethfisto-PC.home (192.168.1.123)
Host is up (0.000082s latency).
All 1000 scanned ports on Cethfisto-PC.home (192.168.1.123) are in ignored states.
Not shown: 1000 closed tcp ports (reset)
MAC Address: 34:13:EB:C2:EB:E2 (Intel Corporate)
Too many fingerprints match this host to give specific OS details
Network Distance: 1 hop

Nmap scan report for LinuxServerSeguridad.home (192.168.1.138)
Host is up (0.000020s latency).
Not shown: 999 closed tcp ports (reset)
PORT      STATE SERVICE
111/tcp   open  rpcbind
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6.32
OS details: Linux 2.6.32
Network Distance: 0 hops

OS detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 256 IP addresses (4 hosts up) scanned in 9.43 seconds
```

Fase: 2

Instalaremos y ejecutaremos Lynis, Chrootkit y Rkhunter para audiciones. Analizaremos configuraciones inseguras, usuarios sin contraseñas y servicios innecesarios activos. Valoraremos si se están aplicando actualizaciones de seguridad. Y revisaremos permisos y procesos activo y accesos recientes.

Para instalar Lynis, Chrootkit y Rkhunter, usaremos los comandos `sudo apt install lynis`, `sudo apt install chkrootkit` y `sudo apt install rkhunter`.

```
LinuxServerSeguridad [Corriendo] - Oracle VirtualBox
Archivo  Máquina  Ver  Entrada  Dispositivos  Ayuda

* Harden compilers like restricting access to root user only [HRDM-7222]
https://cisofy.com/lynis/controls/HRDM-7222/

Follow-up:
- Show details of a test (Lynis show details TEST-ID)
- Check the logfile for all details (less /var/log/lynis.log)
- Read security controls texts (https://cisofy.com)
- Use --upload to upload data to central system (Lynis Enterprise users)

=====
Lynis security scan details:
Hardening index : 62 [#####] 1
Tests performed : 253
Plugins enabled : 1

Components:
- Firewall [U]
- Malware scanner [U]

Scan mode:
Normal [U] Forensics [ ] Integration [ ] Pentest [ ]

Lynis modules:
- Compliance status [U]
- Security audit [U]
- Vulnerability scan [U]

Files:
- Test and debug information : /var/log/lynis.log
- Report data : /var/log/lynis-report.dat

=====
Lynis 3.0.9

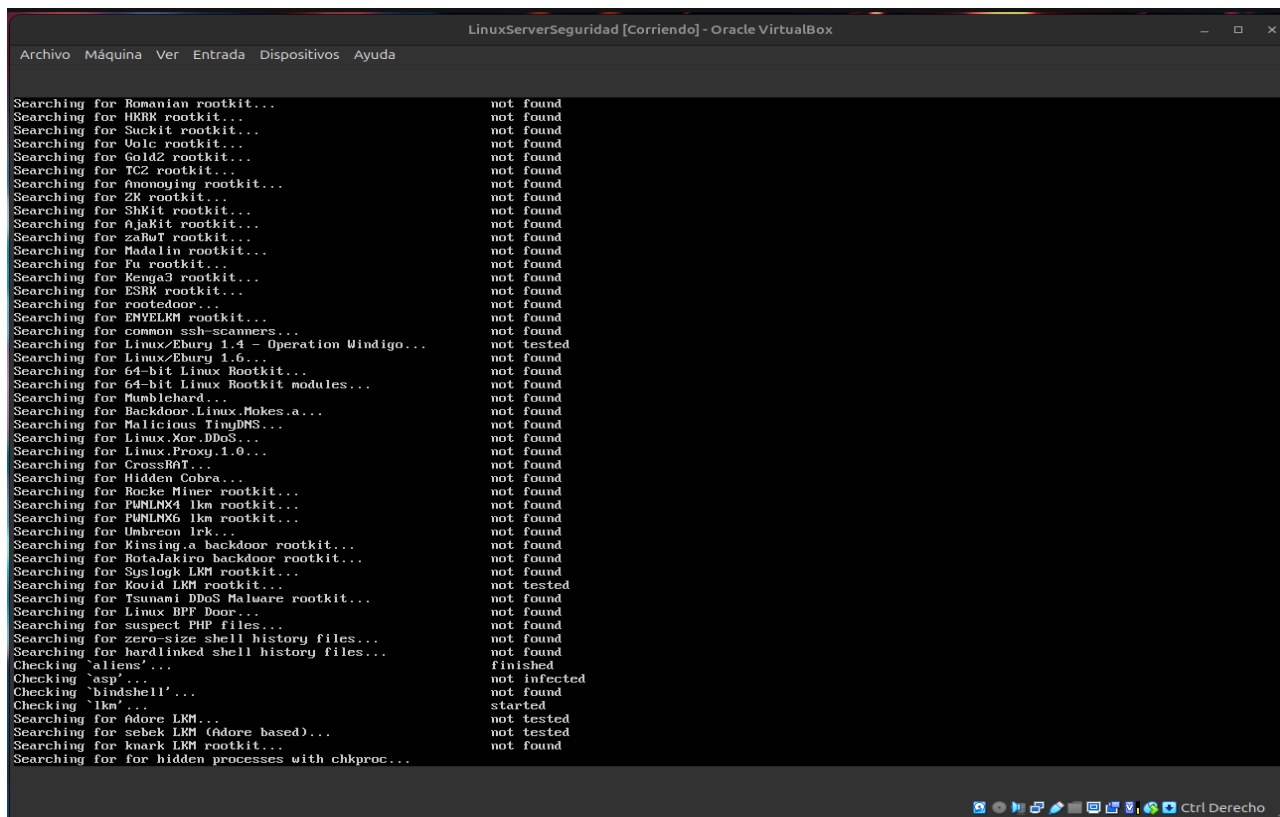
auditing, system hardening, and compliance for UNIX-based systems
(Linux, macOS, BSD, and others)

2007-2021, CISOfy - https://cisofy.com/lynis/
Enterprise support available (compliance, plugins, interface and tools)

=====
[TIP]: Enhance Lynis audits by adding your settings to custom.prfl (see /etc/lynis/default.prfl for all settings)
cethfisto@LinuxServerSeguridad:~$
```

* Después de hacer la auditoria se guardaran logs en /var/log/lynis.log y el informe /var/log/lynis-report.dat

Para ejecutar chrootkit usaremos el comando sudo chkrootkit.

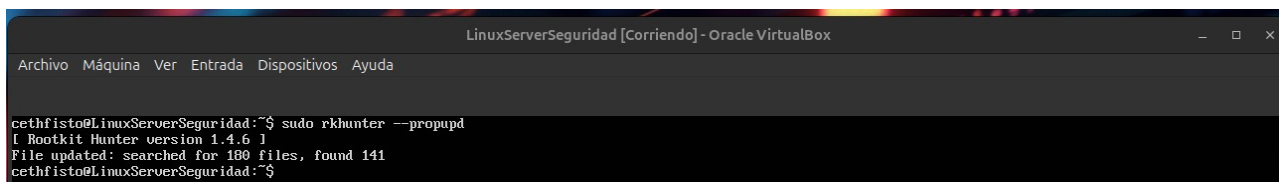


```
LinuxServerSeguridad [Corriendo] - Oracle VirtualBox
Archivo  Máquina  Ver  Entrada  Dispositivos  Ayuda

Searching for Romanian rootkit...      not found
Searching for HKRR rootkit...          not found
Searching for Suckit rootkit...        not found
Searching for Vole rootkit...          not found
Searching for GoldZ rootkit...         not found
Searching for TC2 rootkit...           not found
Searching for Anomoying rootkit...     not found
Searching for ZK rootkit...            not found
Searching for ShKit rootkit...         not found
Searching for AjaKit rootkit...        not found
Searching for zaBot rootkit...         not found
Searching for Madalin rootkit...       not found
Searching for Fu rootkit...            not found
Searching for Kenga3 rootkit...        not found
Searching for ESRK rootkit...          not found
Searching for rootedoor...             not found
Searching for ENVELKM rootkit...       not found
Searching for common ssh-scanners...   not found
Searching for Linux/Ebury 1.4 - Operation Windigo... not tested
Searching for Linux/Ebury 1.6...       not found
Searching for 64-bit Linux Rootkit...  not found
Searching for 64-bit Linux Rootkit modules... not found
Searching for Mumblehard...           not found
Searching for Backdoor.Linux.Makes.a... not found
Searching for Malicious TinyDNS...     not found
Searching for Linux.Xor.DDoS...        not found
Searching for Linux.Proxy.1.0...       not found
Searching for CrossRAT...             not found
Searching for Hidden Cobra...         not found
Searching for Rocke Miner rootkit...   not found
Searching for PWNLNK4 lkm rootkit...   not found
Searching for PWNLNK6 lkm rootkit...   not found
Searching for Umbreon lrm...          not found
Searching for Kinsing.a backdoor rootkit... not found
Searching for Rotajakiro backdoor rootkit... not found
Searching for Syslogk LRM rootkit...   not found
Searching for Kovid LRM rootkit...     not tested
Searching for Tsunami DDoS Malware rootkit... not found
Searching for Linux BPF Door...        not found
Searching for suspect PHP files...     not found
Searching for zero-size shell history files... not found
Searching for hardlinked shell history files... not found
Checking 'aliens'...                  finished
Checking 'asp'...                     not infected
Checking 'bindshell'...               not found
Checking 'lkm'...                     started
Searching for Adore LRM...            not tested
Searching for sebek LRM (Adore based)... not tested
Searching for knark LRM rootkit...     not found
Searching for for hidden processes with chkproc...
```

*En la captura salen los resultados de la auditoria pone not found, que significa que falta algún comando.

Para ejecutar Rkhunter, usaremos el comando sudo rkhunter --propupd.



```
LinuxServerSeguridad [Corriendo] - Oracle VirtualBox
Archivo  Máquina  Ver  Entrada  Dispositivos  Ayuda

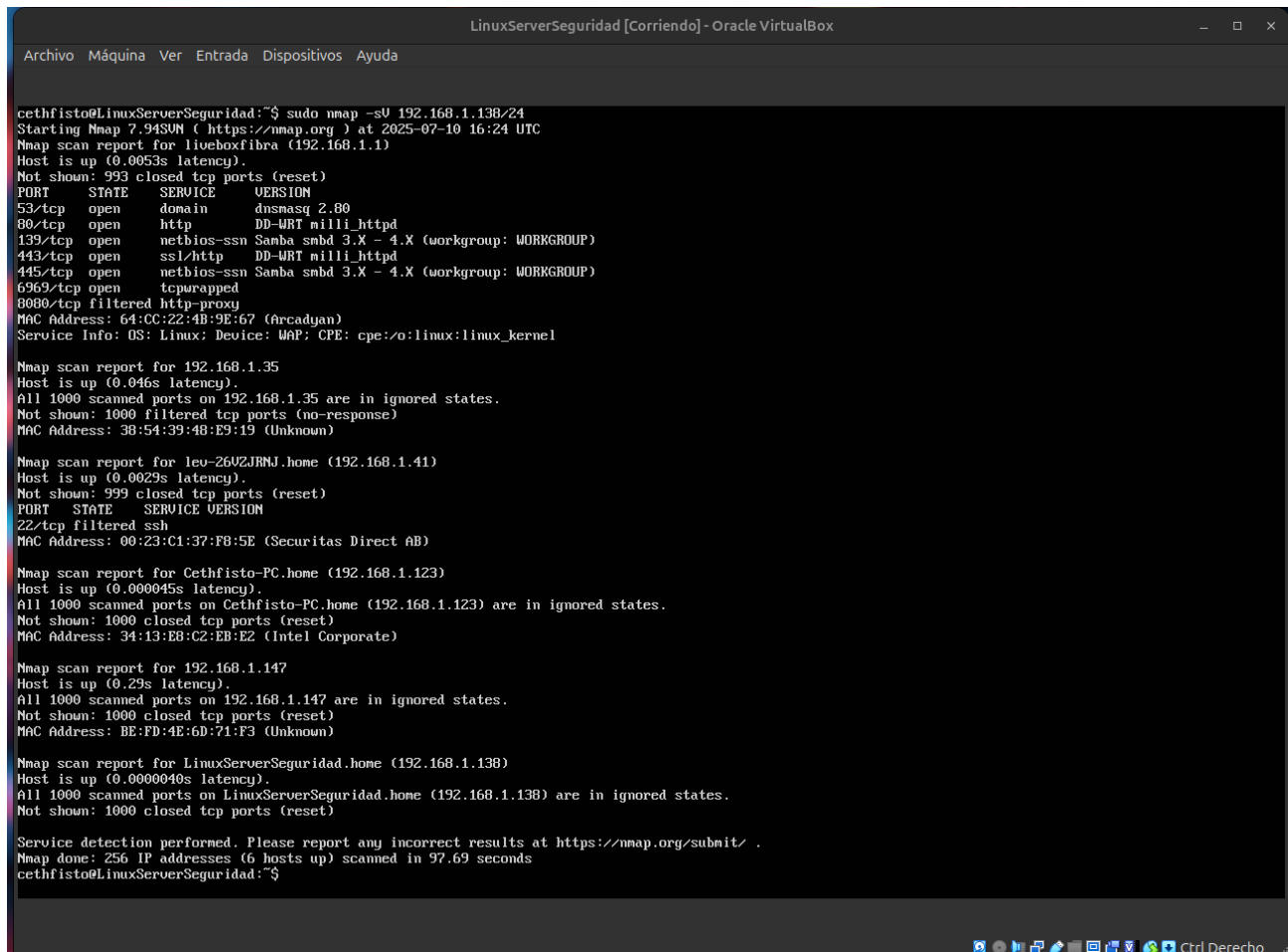
cethfisto@LinuxServerSeguridad:~$ sudo rkhunter --propupd
[ Rootkit Hunter version 1.4.6.1 ]
File updated: searched for 180 files, found 141
cethfisto@LinuxServerSeguridad:~$
```

* El resultado quiere decir que no hay error crítico en el momento de hacer el analisis.

Fase: 3

Identificaremos vectores de ataque desde dentro de la red. Simularemos la ejecución de un script de escaneo tipo atacante desde un cliente. Y registraremos la información que puede conseguir un usuario sin privilegios en la red.

Para buscar debilidades usaremos el comando `sudo nmap -sV 192.168.1.0/24`.



```
cethfisto@LinuxServerSeguridad:~$ sudo nmap -sV 192.168.1.0/24
Starting Nmap 7.94SUN ( https://nmap.org ) at 2025-07-10 16:24 UTC
Nmap scan report for liveboxfibra (192.168.1.1)
Host is up (0.0053s latency).
Not shown: 993 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
53/tcp    open  domain  dnsmasq 2.80
80/tcp    open  http    DD-WRT milli_httpd
139/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
443/tcp   open  ssl/http DD-WRT milli_httpd
445/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
6969/tcp  open  tcpwrapped
8080/tcp   filtered http-proxy
MAC Address: 64:CC:22:4B:9E:67 (Arcadyan)
Service Info: OS: Linux; Device: WAP; CPE: cpe:/o:linux:linux_kernel

Nmap scan report for 192.168.1.35
Host is up (0.046s latency).
All 1000 scanned ports on 192.168.1.35 are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)
MAC Address: 38:54:39:48:E9:19 (Unknown)

Nmap scan report for lev-26VZJRNJ.home (192.168.1.41)
Host is up (0.0029s latency).
Not shown: 999 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    filtered ssh
MAC Address: 00:23:C1:37:F8:5E (Securitas Direct AB)

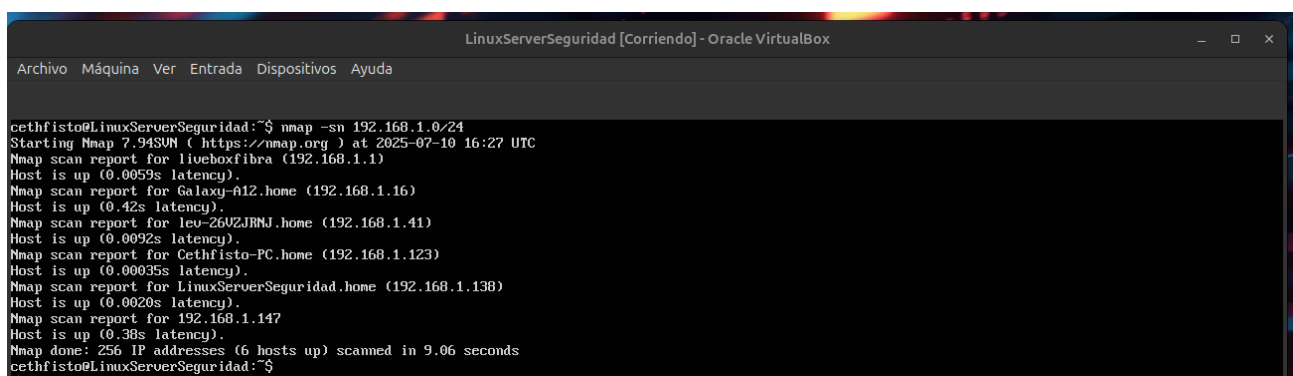
Nmap scan report for Cethfisto-PC.home (192.168.1.123)
Host is up (0.000045s latency).
All 1000 scanned ports on Cethfisto-PC.home (192.168.1.123) are in ignored states.
Not shown: 1000 closed tcp ports (reset)
MAC Address: 34:13:E8:C2:EB:E2 (Intel Corporate)

Nmap scan report for 192.168.1.147
Host is up (0.29s latency).
All 1000 scanned ports on 192.168.1.147 are in ignored states.
Not shown: 1000 closed tcp ports (reset)
MAC Address: BE:FD:4E:6D:71:F3 (Unknown)

Nmap scan report for LinuxServerSeguridad.home (192.168.1.138)
Host is up (0.0000040s latency).
All 1000 scanned ports on LinuxServerSeguridad.home (192.168.1.138) are in ignored states.
Not shown: 1000 closed tcp ports (reset)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 256 IP addresses (6 hosts up) scanned in 97.69 seconds
cethfisto@LinuxServerSeguridad:~$
```

Para hacer un escaneo rápido y simular el supuesto donde un atacante interno sin privilegio. Usaremos el comando `nmap -sn 192.168.1.0/24` que nos mostrará los host activos.



```
cethfisto@LinuxServerSeguridad:~$ nmap -sn 192.168.1.0/24
Starting Nmap 7.94SUN ( https://nmap.org ) at 2025-07-10 16:27 UTC
Nmap scan report for liveboxfibra (192.168.1.1)
Host is up (0.0059s latency)
Nmap scan report for Galaxy-A12.home (192.168.1.16)
Host is up (0.42s latency)
Nmap scan report for lev-26VZJRNJ.home (192.168.1.41)
Host is up (0.0092s latency)
Nmap scan report for Cethfisto-PC.home (192.168.1.123)
Host is up (0.00035s latency)
Nmap scan report for LinuxServerSeguridad.home (192.168.1.138)
Host is up (0.0020s latency)
Nmap scan report for 192.168.1.147
Host is up (0.38s latency)
Nmap done: 256 IP addresses (6 hosts up) scanned in 9.06 seconds
cethfisto@LinuxServerSeguridad:~$
```

Con el comando `nmap -sT -p 21,22,23,80,443,445 192.168.1.0/24`, nos enseñará los servicios disponibles sin ser usuario root.

```
LinuxServerSeguridad [Corriendo] - Oracle VirtualBox
Archivo  Máquina  Ver  Entrada  Dispositivos  Ayuda
80/tcp open      http
443/tcp open      https
445/tcp open      microsoft-ds

Nmap scan report for leu-26U2JRNJ.home (192.168.1.41)
Host is up (0.016s latency).

PORT      STATE      SERVICE
21/tcp    closed    ftp
22/tcp    filtered  ssh
23/tcp    closed    telnet
80/tcp    closed    http
443/tcp   closed    https
445/tcp   closed    microsoft-ds

Nmap scan report for A54-de-Sanyi.home (192.168.1.105)
Host is up (0.087s latency).

PORT      STATE      SERVICE
21/tcp    closed    ftp
22/tcp    closed    ssh
23/tcp    closed    telnet
80/tcp    closed    http
443/tcp   closed    https
445/tcp   closed    microsoft-ds

Nmap scan report for Cethfisto-PC.home (192.168.1.123)
Host is up (0.00017s latency).

PORT      STATE      SERVICE
21/tcp    closed    ftp
22/tcp    closed    ssh
23/tcp    closed    telnet
80/tcp    closed    http
443/tcp   closed    https
445/tcp   closed    microsoft-ds

Nmap scan report for LinuxServerSeguridad.home (192.168.1.138)
Host is up (0.000071s latency).

PORT      STATE      SERVICE
21/tcp    closed    ftp
22/tcp    closed    ssh
23/tcp    closed    telnet
80/tcp    closed    http
443/tcp   closed    https
445/tcp   closed    microsoft-ds

Nmap done: 256 IP addresses (5 hosts up) scanned in 8.27 seconds
```

Para recoger información accesible de la red como usuario. Tendremos varias maneras.

Podremos ver los nombres de host con el comando `nmap -sL 192.168.1.0/24`.

```
LinuxServerSeguridad [Corriendo] - Oracle VirtualBox
Archivo  Máquina  Ver  Entrada  Dispositivos  Ayuda

Nmap scan report for 192.168.1.200
Nmap scan report for 192.168.1.209
Nmap scan report for 192.168.1.210
Nmap scan report for 192.168.1.211
Nmap scan report for 192.168.1.212
Nmap scan report for 192.168.1.213
Nmap scan report for 192.168.1.214
Nmap scan report for 192.168.1.215
Nmap scan report for 192.168.1.216
Nmap scan report for 192.168.1.217
Nmap scan report for 192.168.1.218
Nmap scan report for 192.168.1.219
Nmap scan report for 192.168.1.220
Nmap scan report for 192.168.1.221
Nmap scan report for 192.168.1.222
Nmap scan report for 192.168.1.223
Nmap scan report for 192.168.1.224
Nmap scan report for 192.168.1.225
Nmap scan report for 192.168.1.226
Nmap scan report for 192.168.1.227
Nmap scan report for 192.168.1.228
Nmap scan report for 192.168.1.229
Nmap scan report for 192.168.1.230
Nmap scan report for 192.168.1.231
Nmap scan report for 192.168.1.232
Nmap scan report for 192.168.1.233
Nmap scan report for 192.168.1.234
Nmap scan report for 192.168.1.235
Nmap scan report for 192.168.1.236
Nmap scan report for 192.168.1.237
Nmap scan report for 192.168.1.238
Nmap scan report for 192.168.1.239
Nmap scan report for 192.168.1.240
Nmap scan report for 192.168.1.241
Nmap scan report for 192.168.1.242
Nmap scan report for 192.168.1.243
Nmap scan report for 192.168.1.244
Nmap scan report for 192.168.1.245
Nmap scan report for 192.168.1.246
Nmap scan report for 192.168.1.247
Nmap scan report for 192.168.1.248
Nmap scan report for 192.168.1.249
Nmap scan report for 192.168.1.250
Nmap scan report for 192.168.1.251
Nmap scan report for 192.168.1.252
Nmap scan report for 192.168.1.253
Nmap scan report for 192.168.1.254
Nmap scan report for 192.168.1.255
Nmap done: 256 IP addresses (0 hosts up) scanned in 0.39 seconds
cethfisto@LinuxServerSeguridad:~$
```

Y podremos ver las rutas compartidas por NFS con el comando `showmount -e 192.168.1.100`.

```
LinuxServerSeguridad [Corriendo] - Oracle VirtualBox
Archivo Máquina Ver Entrada Dispositivos Ayuda
cethfisto@LinuxServerSeguridad:~$ showmount -e 192.168.1.100
clnt_create: RPC: Unable to receive
cethfisto@LinuxServerSeguridad:~$ _
```

* En este caso nos sale clnt_create: RPC: Unable to receive, ya que, no tenemos el servidor NFS activado.

Fase: 4

Crearemos una tabla con las vulnerabilidades, nivel de gravedad y solución recomendada. Crearemos una división de la red para limitar el alcance de posibles atacantes. Y propondremos el uso bastionado de servidores, cierre de servicios innecesarios y políticas de logs.

Vamos a realizar un tabla con las posibles debilidades y su posible solución.

Debilidad	Nivel	Solución
Puerto 21 sin cifrado (FTP)	alta	Cambiar FTP por SFTP , FTPS o desactivarlo.
Puerto 23 activo (Telnet)	alta	Eliminar Telnet. Solo usar SSH.
División Samba sin password (-N)	media	Configurar la autenticación obligatoria.
Usuario sin contraseña	alta	Asignar una contraseña o eliminar el usuario.
Servicio HTTP sin HTTPS	media	Instalar certificado TLS y redirigir el trafico HTTP a HTTPS
Servicios innecesarios	baja	Desactivar servicios no usados.
Rootkits no detectados y sin protección	media	Automatizar revisiones con Rkhunter o Chrootkit.
Usuarios con acceso SSH sin 2FA	alta	Añadir autenticación por clave SSH +2FA para usuarios clave.
Sin división de la red	alta	Añadir VLAN para separar clientes, servidor y otras áreas.
No tener logs centralizados	media	Añadir syslog remoto o herramientas tipo Graylog o ELK.

Ahora vamos a realizar una división de la red en subredes para tener una mejor organización de los departamentos y en caso de ataque limitar el daño que puedan causar.

Segmento	Subred	Descripción
Servidores	192.168.10.0	Acceso a admin desde VLAN y SSH limitado.
Clientes de la oficina.	192.168.20.0	Navegación y recursos comunes
Clientes de admin y SAT.	192.168.30.0	Se accede solo por SSH, RC, etc
Clientes vulnerables.	192.168.40.0	Solo internet.

Ahora expondremos una serie de medidas para asegurar el uso bastionado de los servidores con el fin de hacerlos más resistentes frente ataques.

- Desactivar los servicios no usados: para ello usaremos el comando `sudo systemctl disable/stop [nombre-del-servicio]`.
- Desactivar el root por SSH: para ello usaremos el comando `PermitRootLogin no`.
- Usar autenticación por SSH o 2FA: podemos implementar Google Authenticator o Duo para la verificación en dos pasos.
- Configurar correctamente el firewall: para ello usaremos los comando de `ufw` o `iptables`.
- Realizar actualizaciones automáticas: usaremos lo comandos `sudo apt install unattended-upgrades` y `sudo dpkg-reconfigure unattended-upgrades`.

Para la política de logs y su monitorización, deberemos activar los logs de SSH, sudo y errores de autenticación. También usaremos herramientas para centralizar los logs tipo Graylog, ELK o Syslog-ng.

* También podremos crear auditorias de eventos críticos e importantes usando la herramienta Auditd. Para instalarlo y activarlo desde el inicio usaremos los comandos `sudo apt install auditd` y `sudo systemctl enable auditd`

Fase: 5

Expondremos recomendaciones por áreas red, servicios y usuarios. Y la justificación de las propuestas.

Las siguientes recomendaciones en la red son:

- Dividir la red por roles o secciones.
- Bloquear puertos innecesarios.
- Activar el firewall local (UFW).
- Desactivar el NetBIOS/NFS si no se usa.

Las siguientes recomendaciones en puertos y servicios on:

- Cambiar servicios sin cifrado (Telnet o FTP).
- Forzar el uso de HTTPS.
- Vigilar y cerrar servicios no usados.
- Actualizaciones periódicas.

Las siguientes recomendaciones en los usuarios son:

- Eliminar cuentas sin password.
- Añadir la autenticación por SSH.
- Activar o añadir la autenticación en dos factores.
- Revisar usuarios, grupos y permisos.

En definitiva, el uso de estos métodos de seguridad a la hora de mantener nuestra red y equipos protegidos nos ayuda a limitar la exposición de la red, aumentar el control sobre los servicios y usuarios y a detectar posibles fallos de forma rápida.

Solventaremos varios riesgos relacionados con el uso de servicios no cifrados, usuarios mal creados o configurados, falta de división de la red y falta de logs o alertas.